

should be in an SBOM. Generally, an SBOM should include:

- Software component and versions
- Vulnerabilities
- Licences
- Third-party notices
- Usage information
- Alerts and notifications
- Tasks

The software bill of materials life cycle includes creating (and updating) the SBOM, refining it, reviewing it, remediation (in the case of discovered vulnerabilities, based on their severity and on organisational policy), and monitoring for ongoing and frequent updates. Automation, as supported by SCA, ensures the speed necessary for ongoing review of code, delivering updates with the frequency needed to keep pace with contemporary development processes.

Making software secure by design

Rather than looking for vulnerabilities after an issue is revealed, tracking and managing security risks can yield safer products—with fewer headaches. Implementing SCA and a software bill of materials into software development practices will enable automated continuous management without disrupting software development and releases.

When developers look for open source code to deliver a requested functionality or to address a technical challenge, they should evaluate whether that code fits within the best security practices. Clear security parameters can help avoid using code that's riddled with vulnerabilities. And a well-maintained SBOM can help quickly identify and remediate any security flaws that end up in the code. **END** 

References

- [1] <https://info.revenera.com/SCA-RPT-OSS-License-Compliance-2022>
- [2] <https://www.whitehouse.gov/briefing-room/statements-releases/2022/03/21/fact-sheet-act-now-to-protect-against-potential-cyberattacks/>

By: Martin Callinan and Kendra Morton

Martin Callinan is founder and director of Source Code Control Limited.
Kendra Morton is principal, product marketing, at Revenera.

support@efy.in

**Do you have a query,
suggestion or a complaint?**

**You can e-mail it to
support@efy.in
and we will take care
of the rest.**



electronics
FOR YOU
www.electronicforum.com

OpenSource
THE COMPLETE MAGAZINE ON OPEN SOURCE
ForYou
www.opensourceforu.com

EFYGROUP
YOURS SINCE 1969
www.efy.in